

1. Elementos do Diagrama de Fluxo de Dados (DFD) - Nível 1

O sistema foi modelado para delimitar de maneira granular as interações de atores humanos, o isolamento dos microsserviços de processamento semântico de IA, as transições em trânsito e o armazenamento de dados estruturados.

1.1 Entidades Externas (Atores)

- **EE01 - Pesquisador:** Usuário acadêmico autenticado, responsável pela submissão, manutenção e revisão dos dados de seus projetos científicos originais [cite: 2].
- **EE02 - Usuário Corporativo:** Empresas, investidores privados e gestores da administração pública que utilizam a interface do dashboard para descoberta tecnológica e propostas de conexão comercial [cite: 2].
- **EE03 - Administrador Institucional (NIT):** Agente pertencente ao Núcleo de Inovação Tecnológica encarregado de moderar e auditar os projetos submetidos antes de sua publicação oficial [cite: 2].

1.2 Processos Lógicos de Sistema

- **P01 - Autenticar e Gerenciar Conta:** Módulo responsável por operar o cadastro de perfis, controle de sessões via JSON Web Tokens (JWT) e validações de credenciais [cite: 2].
- **P02 - Submeter e Gerenciar Pesquisas:** Processo que recebe, altera e gerencia os dados brutos e descrições técnicas imputadas de forma manual pelo pesquisador [cite: 2].
- **P03 - Moderar e Aprovar Publicações:** Barreira de governança que retém projetos em status pendente de auditoria interna pelo NIT, inviabilizando acessos públicos prematuros [cite: 2].
- **P04 - Motor de Busca e Dashboard:** Indexador que gerencia pesquisas contextuais, aplicação de filtros avançados baseados nos ODS e ordenação parametrizada por relevância [cite: 2].
- **P05 - Canal de Comunicação (Chat Interno):** Mecanismo que provê conversação síncrona/assíncrona direta entre corporações e pesquisadores sob regras estritas de isolamento [cite: 2].
- **P06 - Processamento Semântico e Simplificação por IA:** Microsserviço back-end rodando em ambiente isolado (Deno Edge Functions) encarregado da sanitização de prompts e tradução acessível de dados científicos [cite: 2].

1.3 Depósitos de Dados (Bancos de Dados)

- **D01 - BD de Usuários:** Repositório que gerencia os perfis cadastrais e permissões lógicas de acesso de todos os atores (PII) [cite: 2].
- **D02 - BD de Pesquisas:** Banco persistente onde residem os históricos científicos de projetos, resumos técnicos e logs de auditoria de moderação [cite: 2].
- **D03 - BD de Mensagens e Contatos:** Repositório relacional que armazena os diálogos trocados através das interações do chat interno [cite: 2].
- **D04 - BD/Cache Temporário de Logs da IA:** Área estritamente efêmera designada para a

custódia de dados de auditoria comportamental de prompts [cite: 2].

1.4 Fluxos de Dados (Sinalizações e Transições)

- **F01 - Fluxo de Autenticação:** Tráfego contendo credenciais lógicas criptografadas enviadas da interface para validação no P01 [cite: 2].
- **F02 - Submissão de Projeto:** Carga de dados textuais com as teses e metodologias brutas transmitidas pelo pesquisador para custódia no P02 [cite: 2].
- **F03 - Requisição de Busca:** Tokens textuais e flags de parametrização de filtros direcionados pelas empresas ao processo P04 [cite: 2].
- **F04 - Transmissão de Mensagens:** Pacotes de dados lógicos contendo as conversações interativas trafegadas no chat P05 [cite: 2].
- **F05 - Fluxo de Envio de Contexto (RAG + Prompt):** Tráfego sanitizado contendo dados do projeto estruturados para injeção semântica na API de IA (P06) [cite: 2].
- **F06 - Retorno de Resumo Comercial:** Resposta estruturada devolvida pelo microserviço à interface contendo a tradução semântica gerada [cite: 2].

2. Planilha Mestra de Análise de Ameaças (Framework LINDDUN GO)

A matriz abaixo mapeia sistematicamente as ameaças lógicas sobre o DFD expandido, oferecendo correlação direta com os Requisitos Não Funcionais (RNFs) de privacidade e segurança estipulados para a plataforma [cite: 2, 3].

ID Ameaça	ID Elem.	Tipo Elemento	Categoria LINDDUN	Carta GO	Descrição da Ameaça (Cenário do Projeto)	Risco	Mitigação Proposta (Rastreabilidade RNF)
AME-001	D02	Depósito de Dados	Disclosure of information	DS_Data_01	Usuários maliciosos burlam o back-end e acessam diretamente e pesquisas rejeitadas ou em moderação no BD [cite: 3].	Alto	Uso de criptografia at-rest e aplicação estrita de PostgreSQL RLS por perfil [cite: 3].

ID Ameaça	ID Elem.	Tipo Elemento	Categoria LINDDUN	Carta GO	Descrição da Ameaça (Cenário do Projeto)	Risco	Mitigação Proposta (Rastreabilidade RNF)
AME-002	F01	Fluxo de Dados	Disclosure of information	DF_Credentials_01	Interceptação de e-mails e senhas em trânsito no fluxo de login por ausência de TLS [cite: 3].	Alto	Forçar HTTPS com TLS 1.3 e aplicação de hashing com salt (Bcrypt) no Supabase Auth [cite: 3].
AME-003	D01 / D02	Depósito de Dados	Non-compliance	NC_Law_01	Retenção vitalícia de PII de contas excluídas ou projetos removidos , violando a LGPD [cite: 3].	Médio	Rotinas automatizadas de hard delete para contas e anonimização de projetos ocultos [cite: 3].
AME-004	P05	Processo	Linkability	LK_Chat_04	Atacantes correlacionam metadados do chat para prever parcerias comerciais antes do anúncio oficial [cite: 3].	Médio	Minimização de metadados em logs e mascaramento de IDs de sessão transacionais [cite: 3].
AME-005	P04	Processo	Identifiability	ID_Search_02	Raspagem automatizada (scraping) de e-mails de	Médio	Mascarar contatos na busca pública, exigindo autenticação para

ID Ameaça	ID Elem.	Tipo Elemento	Categoria LINDDUN	Carta GO	Descrição da Ameaça (Cenário do Projeto)	Risco	Mitigação Proposta (Rastreabilidade RNF)
					pesquisadores expostos no motor de busca pública [cite: 3].		abrir o chat [cite: 3].
AME-IA-001	P06 / F05	Processo / Fluxo	Non-compliance	NC_Law_02	Vazamento difuso de PII e propriedade intelectual para o ecossistema público de treinamento de terceiros [cite: 3].	Alto	RNF-PRIV-01: Contratos/configurações de API com política estrita de opt-out de treinamento [cite: 3].
AME-IA-002	P06	Processo	Identifiability	ID_Data_03	A IA reinsere nomes de autores ou laboratórios no resumo simplificado público de projetos que exigiam sigilo [cite: 3].	Médio	RNF-PRIV-02: Ofuscação preventiva de entidades nomeadas sensíveis via System Prompt [cite: 3].
AME-IA-003	P06	Processo	Disclosure of information	DS_Process_02	O microserviço de IA indexa ou lê de forma acidental pesquisas que ainda	Alto	RNF-SEG-01: Regras granulares de API nativas isolando privilégios do agente

ID Ameaça	ID Elem.	Tipo Elemento	Categoria LINDDUN	Carta GO	Descrição da Ameaça (Cenário do Projeto)	Risco	Mitigação Proposta (Rastreabilidade RNF)
					estão pendentes de moderação pelo NIT [cite: 3].		de IA no back-end [cite: 3].
AME-IA-004	P04	Processo	Disclosure of information	DS_Search_03	Ataques de Prompt Injection via barra de busca forçam a LLM a vaziar metodologias internas protegidas [cite: 3].	Alto	RNF-SEG-02: Camadas de sanitização de dados e arquitetura RAG restrita a metadados autorizados [cite: 3].
AME-IA-005	P02	Processo	Unawareness	UA_Trust_01	O pesquisador alimenta o sistema sem saber que seu texto científico passará por modificação semântica via IA [cite: 3].	Baixo	RNF-PRIV-03 e RNF-GOV-01: Bloqueio por termo de consentimento e revisão obrigatória humana antes de publicar [cite: 3].
AME-IA-006	P06	Processo	Unawareness	UA_Data_02	Alucinações da IA distorcem a realidade científica, gerando falsas promessas	Médio	RNF-GOV-02: Ancoragem de fidelidade técnica e botão de denúncia pública

ID Ameaça	ID Elem.	Tipo Elemento	Categoria LINDDUN	Carta GO	Descrição da Ameaça (Cenário do Projeto)	Risco	Mitigação Proposta (Rastreabilidade RNF)
					s de solução para as empresas [cite: 3].		que suspende o resumo [cite: 3].
AME-IA-007	D02	Depósito de Dados	Disclosure of information	DS_Patent_01	O resumo gerado pela IA expõe detalhes excessivos da metodologia, quebrando o ineditismo exigido para patentes [cite: 3].	Alto	RNF-SEG-03: Restrições severas de profundidade de técnica e granularidade na geração da sinopse comercial [cite: 3].
AME-IA-008	D04	Depósito de Dados	Non-compliance	NC_Log_01	Armazenamento perpétuo de históricos de prompts, contextos e respostas brutas da IA criando passivos desnecessários [cite: 3].	Médio	RNF-PRIV-04: Rotinas automatizadas de hard delete dos logs transacionais em no máximo 7 dias [cite: 3].